

GUÍA METODOLÓGICA DETALLADA

Análisis, Cálculo e Interpretación de Resultados

TABLA DE CONTENIDOS

1. Introducción Metodológica
2. Estructura de Análisis
3. Cálculo de Indicadores Clave (KPIs)
4. Matriz de Madurez y Scoring
5. Análisis por Dominio
6. Interpretación de Resultados
7. Benchmarking Comparativo
8. Generación de Recomendaciones

1. INTRODUCCIÓN METODOLÓGICA

Esta encuesta de ciberseguridad integra tres marcos internacionales de reconocido prestigio:

1.1 NIST Cybersecurity Framework v2.0

Proporciona estructura de 5 funciones core (Identify, Protect, Detect, Respond, Recover) y 6 niveles de madurez (1. Incomplete a 6. Optimized).

1.2 ISO/IEC 27001:2022

Define 93 controles de seguridad (Anexo A) organizados en 4 categorías: gobernanza, personas, procesos, tecnología.

1.3 Metodología Mercury AVRQ

Enfoque de cuantificación de riesgos basado en valor de activos (Asset Value-based Risk Quantification), con automatización y scoring empírico.

1.4 Directiva NIS2

Requisitos operacionales y técnicos para Entidades Esenciales e Importantes en la Unión Europea.

2. ESTRUCTURA DE ANÁLISIS

2.1 Dominios de Evaluación

La encuesta se organiza en 12 dominios:

Dominio	Abreviatura	Preguntas	Peso
Gobernanza y Riesgos	GR	P2	20%
Vulnerabilidades	VUL	P3	15%
Pruebas de Seguridad	PEN	P4	10%
SIEM e Incidentes	SIEM	P5	15%
Capacitación de Empleados	CAP	P6	10%
Cumplimiento Normativo	NORM	P7	10%
Continuidad	CONT	P8	5%
Cadena de Suministro	SUPL	P9	5%
Controles Técnicos	CTRL	P10	10%
Inteligencia de Amenazas	INT	P11	5%

Total: 100% | Peso máximo: 5 puntos por pregunta

2.2 Modelo de Respuesta

Cada pregunta utiliza una escala Likert modificada de 1-5:

1 = Inexistente / Ad hoc / Manual / Sin documentación
 2 = Básico / Inicial / Parcialmente documentado
 3 = Definido / Establecido / Completamente documentado
 4 = Gestionado / Medido / Automatizado parcialmente / Monitorizado
 5 = Optimizado / Continuo / Totalmente automatizado / En mejora constante

Ejemplo de interpretación:

- Pregunta P3.2: "¿Se utiliza un sistema de puntuación (CVSS/EPSS)?"
- Respuesta "No existe sistema formal" = 1 punto
- Respuesta "Sistema propietario" = 3 puntos
- Respuesta "CVSS y EPSS integrados" = 5 puntos

3. CÁLCULO DE INDICADORES CLAVE (KPIs)

3.1 Índice Global de Madurez (IGM)

Fórmula:

$$IGM = (\sum \text{Puntuación por Dominio} \times \text{Peso del Dominio}) / 5$$

Donde:

- **$\sum$ Puntuación por Dominio** = Promedio ponderado de respuestas en cada dominio
- **Peso del Dominio** = Porcentaje asignado (ver Tabla 2.1)
- **Divisor 5** = Normalización a escala 0-5

Ejemplo de cálculo:

Dominio GR (Gobernanza):

- P2.1 (Metodología formal): 4 puntos
- P2.2 (Cuantificación AVRQ): 2 puntos
- P2.3 (Planes de tratamiento): 3 puntos

Promedio GR = $(4+2+3)/3 = 3.0$ puntos

Contribución = $3.0 \times 20\% = 0.60$

Dominio VUL (Vulnerabilidades):

- P3.1 (Escaneo frecuencia): 4 puntos
- P3.2 (Priorización CVSS): 4 puntos
- P3.3 (Gestión de parches): 3 puntos

Promedio VUL = $(4+4+3)/3 = 3.67$ puntos

Contribución = $3.67 \times 15\% = 0.55$

IGM = $(0.60 + 0.55 + \dots [\text{otros dominios}] / 5$

3.2 Puntuación por Dominio (PD)

Fórmula:

$PD[x] = (\sum \text{Respuestas en Dominio} / \text{Nº de Preguntas}) / 5$

Produce valor 0.0-1.0 para cada dominio, facilitando identificación de brechas.

3.3 Índice de Madurez NIST CSF (NIM)

Mapea resultados a niveles NIST (1-6):

NIM Puntuación = $IGM \times 6$

Si NIM Puntuación $\leq 1.2 \rightarrow$ Nivel 1 (Incomplete)

Si $1.2 < \text{NIM} \leq 2.4 \rightarrow$ Nivel 2 (Managed)

Si $2.4 < \text{NIM} \leq 3.6 \rightarrow$ Nivel 3 (Defined)

Si $3.6 < \text{NIM} \leq 4.8 \rightarrow$ Nivel 4 (Quantitatively Managed)

Si $\text{NIM} > 4.8 \rightarrow$ Nivel 5/6 (Optimized)

3.4 Índice de Conformidad Normativa (ICN)

Calcula conformidad con NIS2, ISO 27001 basándose en dominio NORM:

Fórmula:

$ICN = (PD[NORM] \times 100)$

$ICN \geq 80\% \rightarrow$ Conforme

$ICN 60-79\% \rightarrow$ Parcialmente conforme

$ICN < 60\% \rightarrow$ No conforme

3.5 Retorno sobre Inversión en Ciberseguridad (ROICS)

Estima impacto financiero de inversiones de seguridad usando metodología Mercury AVRQ:

Fórmula:

$ROICS = (\text{Riesgos Mitigados en } \text{€} - \text{Costos de Mitigación en } \text{€}) / \text{Costos de Mitigación en } \text{€} \times 100\%$

Donde:

- Riesgos Mitigados = AVRQ Score $\times$ Valor de Activo Protegido $\times$ Probabilidad de Incidente
- Costos de Mitigación = Inversión en controles + Operación anual

Ejemplo:

Inversión en SIEM: €50.000
Operación anual: €15.000
Total costo 3 años: €95.000

Riesgos mitigados (estimado):

- Pérdida por ransomware prevenido: €300.000
 - Mejora en MTTR (reducción de 8h a 2h) = €80.000
 - Cumplimiento NIS2 (evitar sanciones €10M $\times$ 0.1% probabilidad): €10.000
- Total mitigado 3 años: €390.000

$ROICS = (390.000 - 95.000) / 95.000 \times 100\% = 310\%$

4. MATRIZ DE MADUREZ Y SCORING

4.1 Matriz de Puntuación por Pregunta

Cada pregunta se puntúa independientemente:

Puntuación	Descripción NIST CSF	ISO 27001	Mercury AVRQ
1	Incomplete	No implementado	Ad hoc, sin automatización
2	Managed	Parcialmente implementado	Documentado, manual
3	Defined	Implementado	Documentado, parcialmente automatizado
4	Quantitatively Managed	Medido, monitoreado	Automatizado, métricas disponibles
5	Optimized	Optimizado, mejora continua	Totalmente automatizado, inteligencia artificial

4.2 Matriz de Brecha (Gap Analysis)

Para cada dominio, se calcula brecha respecto a objetivo:

Brecha = Puntuación Objetivo (5.0) - Puntuación Actual
Prioridad = Brecha $\times$ Peso del Dominio $\times$ Criticidad Regulatoria

Ejemplo:

Dominio GR actual: 2.5 puntos
Dominio GR objetivo: 4.5 puntos
Brecha = $4.5 - 2.5 = 2.0$
Prioridad = $2.0 \times 20\% \times 1.0$ (crítico NIS2) = 0.40 (ALTA)

Dominio SUPL actual: 3.0 puntos
Dominio SUPL objetivo: 4.5 puntos
Brecha = $4.5 - 3.0 = 1.5$
Prioridad = $1.5 \times 5\% \times 0.8$ (medio) = 0.06 (BAJA)

5. ANÁLISIS POR DOMINIO

5.1 Dominio Gobernanza y Riesgos (GR)

Propósito: Evaluar existencia de marcos formales de gestión de riesgos.

Preguntas clave:

- P2.1: Metodología formal (ISO 27005, NIST SP 800-30)
- P2.2: Cuantificación AVRQ/FAIR
- P2.3: Planes de tratamiento con propietarios

Interpretación:

Puntuación 1-2: Riesgos identificados de forma ad hoc o inexistentes.
Recomendación: Implementar ISO 27005 con urgencia.

Puntuación 3: Marco establecido pero sin cuantificación monetaria.
Recomendación: Adoptar AVRQ para cuantificación y ROI.

Puntuación 4-5: Marcos avanzados con automatización y análisis continuo.
Recomendación: Optimizar mapeo a Mercury AVRQ, integración IA/ML.

5.2 Dominio Vulnerabilidades (VUL)

Propósito: Evaluar capacidad de identificación y remediación de vulnerabilidades.

Preguntas clave:

- P3.1: Frecuencia de escaneo
- P3.2: Priorización CVSS/EPSS
- P3.3: MTTR (Mean Time To Remediation)

KPIs calculados:

Velocidad de Remediación = $(\text{Vulnerabilidades Críticas Remediadas} / \text{Total Detectadas}) / \text{MTTR}$

Cobertura de Scanning = $(\text{Activos Escaneados} / \text{Total de Activos}) \times 100\%$

Índice de Riesgo Residual = $\sum (\text{CVSS Score} \times \text{Días Abiertos} / 365)$ para vulnerabilidades antiguas

Benchmarks internacionales:

Excelente (>85%):

- Scan coverage: >95%
- MTTR críticos: <7 días
- Tasa de remediación: >90%

Bueno (70-85%):

- Scan coverage: 85-95%
- MTTR críticos: 7-14 días
- Tasa: 75-90%

Aceptable (50-70%):

- Scan coverage: 70-85%
- MTTR críticos: 14-30 días
- Tasa: 50-75%

Requiere mejora (<50%):

- Scan coverage: <70%
- MTTR críticos: >30 días
- Tasa: <50%

5.3 Dominio SIEM e Incidentes (SIEM)

Propósito: Evaluar capacidad de detección y respuesta a incidentes.

Preguntas clave:

- P5.2: Tasa de falsos positivos
- P5.2: MTDD (Mean Time To Detect)
- P5.3: MTTR (Mean Time To Respond)

KPIs avanzados:

Eficiencia de Detección = $\text{MTDD} / \text{Complejidad del Ataque}$
(Idealmente <1 hora para ataques complejos)

Calidad de Alertas = $(\text{Alertas Verdaderas Positivas}) / (\text{Total de Alertas}) = 1 - \text{FPR}$
(Idealmente >95%, es decir FPR <5%)

Velocidad de Respuesta = MTTR para incidentes críticos
(Objetivo NIS2: <1 hora inicial, <24h notificación)

Cobertura de Incidentes = $(\text{Incidentes Detectados internamente}) / (\text{Total detectados después, por cliente, etc.})$

5.4 Dominio Capacitación de Empleados (CAP)

Propósito: Evaluar efectividad de programas de concienciación.

Preguntas clave:

- P6.2: Tasa de aprobación en evaluaciones
- P6.3: Click rate en phishing simulado
- P6.4: Tasa de reporte de amenazas

Métricas de Comportamiento:

$$\text{Índice de Resiliencia del Usuario} = (\% \text{ de emails reportados} - \% \text{ de clicks}) \times 100$$

(Idealmente >50%; >20% es aceptable)

$$\text{Mejora Conductual} = (\text{Click Rate Pre-Training}) - (\text{Click Rate Post-Training}) / \text{Pre} \times 100\%$$

(Idealmente >30% reducción)

$$\text{Tasa de Reporte Real} = (\text{Emails maliciosos reportados por empleados}) / (\text{Total de emails maliciosos}) \times 100\%$$

(Idealmente >50% en 6 meses post-training)

$$\text{ROI de Capacitación} = (\text{Incidentes prevenidos} \times \text{costo promedio incidente}) / (\text{Costo de capacitación})$$

(Típicamente 5:1 a 10:1 después de 18 meses)

5.5 Dominio Cumplimiento Normativo (NORM)

Propósito: Evaluar alineación con NIS2, ISO 27001, GDPR.

Mapeo a requisitos:

NIS2 Entidades Esenciales - 21 medidas obligatorias:

- ✓ Análisis de riesgos
- ✓ Medidas de seguridad (técnicas y organizacionales)
- ✓ Gestión de incidentes (24h inicial, 72h notificación)
- ✓ Continuidad (RTO/RPO definidos)
- ✓ Capacitación de altos directivos

ISO 27001 - 93 controles a seleccionar según riesgo:

- ✓ A.5: Controles de gobernanza
- ✓ A.6: Personas y gestión de acceso
- ✓ A.7: Procesos y políticas
- ✓ A.8: Gestión de proveedores
- ✓ Otros 45+ controles según riesgo

GDPR (Art. 32-34):

- ✓ Medidas técnicas y organizacionales
- ✓ Notificación de violaciones (<72h)
- ✓ Evaluación de impacto (DPIA)

6. INTERPRETACIÓN DE RESULTADOS

6.1 Clasificación de Organizaciones

Basado en IGM (Índice Global de Madurez):

Tier 1 - EMERGENTE (IGM < 1.5)

- Riesgos: No cuantificados
- Procesos: Inexistentes o ad hoc
- Automatización: Nula
- Acción inmediata: Implementación de governance básico
- Horizonte: 24 meses para Tier 2

Tier 2 - BÁSICO (IGM 1.5 - 2.5)

- Riesgos: Identificados cualitativamente
- Procesos: Documentados, ejecución manual
- Automatización: Herramientas aisladas
- Acción: Consolidación de marcos (ISO 27001)
- Horizonte: 18-24 meses para Tier 3

Tier 3 - ESTABLECIDO (IGM 2.5 - 3.5)

- Riesgos: Parcialmente cuantificados
- Procesos: Documentados e implementados
- Automatización: SIEM, escaneo de vuln, ITSM
- Acción: Integración de sistemas, métricas avanzadas
- Horizonte: 12-18 meses para Tier 4

Tier 4 - GESTIONADO (IGM 3.5 - 4.5)

- Riesgos: Cuantificados con FAIR/AVRQ
- Procesos: Medidos y optimizados
- Automatización: Workflows, SOAR, IA básico
- Acción: Optimización de alertas, predicción de amenazas
- Horizonte: 12+ meses para Tier 5

Tier 5 - OPTIMIZADO (IGM > 4.5)

- Riesgos: Cuantificados continuamente, modelado predictivo
- Procesos: Mejora continua con IA/ML
- Automatización: End-to-end, inteligencia adaptativa
- Acción: Investigación, innovación, thought leadership

6.2 Análisis de Brechas Críticas

Para cada brecha identificada, se calcula:

$\text{Criticidad} = \text{Brecha} \times \text{Impacto Potencial} \times \text{Exposición Regulatoria}$

Donde:

- Brecha: diferencia entre actual y objetivo (0-1.0)
- Impacto Potencial: valor en riesgo (€)
- Exposición Regulatoria: multa máxima NIS2/GDPR (€)

Prioridades:

1. Criticidad > 0.7 → Acción inmediata (<3 meses)
2. Criticidad 0.5-0.7 → Acción corto plazo (3-6 meses)
3. Criticidad 0.3-0.5 → Acción medio plazo (6-12 meses)
4. Criticidad < 0.3 → Acción largo plazo (>12 meses)

7. BENCHMARKING COMPARATIVO

7.1 Comparación con Pares Sectoriales

Los resultados se comparan con medianas de sector:

Sector Financiero (Benchmarks España 2024):

- IGM mediano: 3.2
- Dominio GR: 3.8 (gestión de riesgos avanzada)
- Dominio SIEM: 3.5 (SOC requerido regulatoriamente)
- Dominio CAP: 3.0 (capacitación regulada)

Sector Sanidad (Benchmarks España 2024):

- IGM mediano: 2.8
- Dominio CTRL: 2.5 (infraestructura legacy)
- Dominio CAP: 2.2 (personal médico vs TI)
- Dominio SIEM: 2.3 (inversión insuficiente)

Administración Pública (Benchmarks España 2024):

- IGM mediano: 2.5
- Dominio NORM: 3.5 (requisitos NIS2)
- Dominio GR: 2.0 (toma de decisiones centralizada)
- Dominio CAP: 2.1 (rotación de personal)

8. GENERACIÓN DE RECOMENDACIONES

8.1 Matriz de Recomendaciones

Cada brecha genera recomendaciones basadas en:

$\text{Prioridad} \times \text{Complejidad} \times \text{Costo} \times \text{Impacto} = \text{Score de Recomendación}$

Recomendaciones de Alto Score se implementan primero.

Ejemplo:

- Implementar SIEM: $\text{Prioridad } 0.9 \times \text{Complejidad } 0.7 \times \text{Costo } 0.6 \times \text{Impacto } 0.8 = 0.30$
- Mejorar MFA: $\text{Prioridad } 0.85 \times \text{Complejidad } 0.3 \times \text{Costo } 0.7 \times \text{Impacto } 0.6 = 0.11$
- Capacitación phishing: $\text{Prioridad } 0.7 \times \text{Complejidad } 0.2 \times \text{Costo } 0.3 \times \text{Impacto } 0.5 = 0.02$

Orden: SIEM > MFA > Capacitación

8.2 Plan de Acción Personalizado

Se genera roadmap con:

- Hitos a 3, 6, 12, 24 meses
- Inversión estimada por fase
- Responsables y dependencias
- Métricas de éxito
- Riesgos de implementación

9. NOTAS TÉCNICAS Y LIMITACIONES

9.1 Validez Estadística

- Confiabilidad: ± 0.3 puntos (IC 95%)
- Sensibilidad: Cambios > 0.5 puntos son significativos
- Sesgo: Respuestas propensas a optimismo ($+0.2$ - 0.3 puntos)

9.2 Actualización Recomendada

- Trimestral para dominios críticos (GR, SIEM, NORM)
- Anual para dominios operacionales
- Post-incidente para refinación

Fin de Guía Metodológica

Versión 2.0 / Enero 2026